Synégo

ATELIER SIMULATION DE PROJET AGILE · ISITECH

Rapport de *projet*

Un service en ligne complet pour une activité de bien-être en entreprise : site vitrine, prise de rendez-vous, espace client sécurisé et back-office de la coach, hébergés sur un VPS administré par l'équipe.

SPRINT	Sprint 1 · du lundi 2 au jeudi 5 novembre 2026
SERVICE	https://172-239-9-200.sslip.io
CODE	github.com/luidgi-gaudin/projetkine
ÉQUIPE	Luidgi GAUDIN (PO), Victor (Scrum Master), Nayir, Céline, Azzouz, Nathan · 3 Dev, 3 Réseau
VERSION	4 novembre 2026, avant la Sprint Review

Sommaire

01	Le client et son besoin	reformulation, ce que nous livrons
02	Organisation de l'équipe	rôles Scrum, Trello, règles de communication
03	Sprint Planning	Sprint Goal, Definition of Done, backlogs
04	Déroulé du sprint	journal jour par jour
05	Changements demandés par le client	négociation et arbitrages
06	Urgences et incidents	repérer, tracer, traiter, expliquer
07	Cadre technique imposé	VPS, accès privé, base SQL, sauvegarde, tickets
08	Fiches de preuve	ce que le PO montrera au client
09	Architecture et règles d'accès	schéma à jour, qui parle à quoi
10	Definition of Done : état par story	ce qui est fait, partiel, à faire
11	Rétrospective	Start / Stop / Continue, collaboration Dev-Réseau
12	Bilan et préparation de la démo	risques, plan de la Sprint Review

01

Le client et son besoin

Notre client est une **coach bien-être, kinésithérapeute de formation**, qui accompagne des entreprises et des particuliers : séminaires d'équipe, ateliers de posture et de respiration, suivi individuel. Elle travaille **presque entièrement à distance, en visio Google Meet**, sans locaux.

Ce que le client nous a dit, et ce que nous en avons compris

CE QUE LE CLIENT EXPRIME	CE QUE NOUS EN FAISONS
« Je veux que les gens ressentent du calme dès qu'ils arrivent. »	Un site vitrine apaisant et propre à la marque : palette du logo, animations lentes, un exercice de respiration (cohérence cardiaque) dès l'accueil, aucun visuel « générique ».
« Mes séminaires doivent être mis en avant. »	Une page Séminaires avec les formats, une journée type et une FAQ, qui mène à une demande de devis.
« Pas de prix, tout est sur devis. »	Aucun tarif nulle part sur le site ; chaque appel à l'action mène à un devis ou à un rendez-vous.
« Les prospects et mes clients ne réservent pas la même chose. »	Deux parcours de réservation Calendly : audit séminaire et appel découverte pour les prospects ; séance de suivi **réservée aux clients signés**. Aucune confirmation manuelle.
« Mes clients doivent retrouver leurs documents en toute confidentialité. »	Un espace client privé : documents, rendez-vous, demandes ; connexion par e-mail, SMS ou Google.
« Je veux gérer tout ça simplement. »	Un back-office pour la coach : tableau du jour, clients, rendez-vous, demandes, notes privées, liaison Calendly en un clic, nomination d'autres coachs.
« Je ne suis pas médecin. »	Un avertissement clair : prestations de bien-être et de prévention, ni diagnostic ni traitement. Pas de données de santé dans l'espace client ni dans les notes.

Ce que nous livrons

Non pas « un site » ni « un serveur », mais un **service en ligne de bout en bout** :

Ce que voient les utilisateurs

- Site vitrine en français et en anglais, clair ou sombre, adapté au téléphone.
- Réservation en ligne, ajout à l'agenda (Google, Apple, Samsung, Outlook), rappels par e-mail 48 h et 24 h avant.
- Espace client et back-office de la coach.

Ce qui fait tenir le service

- Un VPS Linux administré par l'équipe, pare-feu, HTTPS valide.
- Base PostgreSQL aux comptes limités, accessible uniquement par tunnel SSH.
- Sauvegardes chiffrées et restauration testée, surveillance, déploiement automatique.

02

Organisation de l'équipe

Rôles Scrum

RÔLE	QUI	ENGAGEMENT
Product Owner	Luidgi GAUDIN DEV	Seul interlocuteur du client, du briefing à la Sprint Review. Parle valeur, jamais technique. Priorise le backlog.
Scrum Master	Victor RÉSEAU	Garant du processus. Trace chaque obstacle dans Trello (carte rouge « Obstacle »), en particulier quand un profil Dev attend un profil Réseau, ou l'inverse.
Équipe de développement	DEV Nayir, Céline, Luidgi RÉSEAU Azzouz, Nathan, Victor	Profils Dev et Réseau ensemble sur chaque story : aucune story « par discipline ». Le PO et le SM réalisent aussi.

Règles de communication

- Le client ne parle **qu'au PO** : briefing, points quotidiens, demande de démo, Sprint Review.
- Tout ce que le PO montre est formulé **sans jargon**. Des phrases types sont prêtes pour chaque urgence (voir partie 06).
- Une fonctionnalité n'existe pour le client que si elle est **démontrée** : chaque story terminée a sa fiche de preuve (partie 08).

Outil de gestion : Trello

Le client a demandé Trello à la place de Jira. Le tableau **« Synégo · Sprint 1 »** se crée en une commande à partir du backlog versionné dans le dépôt (`docs/scrum/backlog.json`, script `scripts/trello_import.py`), ce qui garantit que l'outil et le code racontent la même histoire.

LISTE	CONTENU
Infos sprint	Sprint Goal, Definition of Done (checklist), règles du tableau
Product Backlog	13 stories verticales, chacune avec sa checklist DoD et sa fiche de preuve
Sprint Backlog	47 tâches étiquetées Dev, Réseau ou Mixte, reliées à leur story
En cours · À démontrer au PO · Terminé	le flux de travail, mis à jour en temps réel
Daily & Rétro	un compte-rendu par Daily (modèle à dupliquer), la rétrospective

Étiquettes : DEV RÉSEAU MIXTE OBSTACLE URGENCE CHANGEMENT. Le tableau est partagé avec le client (rôle observateur) dès le premier jour.

03

Sprint Planning

Sprint Goal

> *À la fin du sprint, un visiteur trouve Synégo à une adresse sécurisée, découvre les séminaires, réserve un premier rendez-vous ou demande un devis, et un client retrouve ses documents dans un espace privé. La coach administre le tout depuis un accès réservé, surveillé et sauvegardé.*

Definition of Done

La base commune imposée, complétée par nos propres critères (en *italique*) :

1. fonctionne depuis l'extérieur du réseau de test (adresse publique) ;
2. HTTPS valide (cadenas, aucun avertissement) ;
3. règles d'accès documentées : qui peut parler à quoi (partie 09) ;
4. schéma d'architecture à jour ;
5. brique surveillée, avec une alerte configurée ;
6. données sensibles accessibles uniquement par le tunnel SSH ou le VPN ;
7. une sauvegarde existe et sa restauration a été testée ;
8. *textes en français et en anglais, thème clair et sombre, affichage mobile vérifié ;*
9. *la CI est verte : build sans erreur ni avertissement, tests, migrations à jour, audit de sécurité ;*
10. *aucun secret dans le dépôt (clés et mots de passe uniquement dans `.env`) ;*
11. *fiche de preuve remplie dans la carte Trello ;*
12. démontrée au PO, puis acceptée.

Product Backlog

13 stories, toutes formulées du point de vue du client et toutes **mixtes** : chacune mobilise au moins un profil Dev et un profil Réseau. Total : 55 points.

#	STORY (VALEUR POUR LE CLIENT)	PRIORITÉ	PTS	PROFILS
S1	Mes visiteurs accèdent à mon site à une adresse simple et sécurisée	Critique	5	DEV RÉSEAU
S2	Mes visiteurs découvrent mes séminaires et me demandent un devis	Critique	5	DEV RÉSEAU
S7	Mes informations sensibles ne sont accessibles que par un accès privé	Critique	8	DEV RÉSEAU
S3	Un prospect réserve un audit ou un appel découverte sans m'appeler	Haute	3	DEV RÉSEAU
S4	Mes clients se connectent par e-mail, SMS ou Google	Haute	5	DEV RÉSEAU
S5	Mes clients retrouvent leurs documents en toute confidentialité	Haute	5	DEV RÉSEAU
S8	Si une information est effacée par erreur, on la récupère	Haute	5	DEV RÉSEAU

#	STORY (VALEUR POUR LE CLIENT)	PRIORITÉ	PTS	PROFILS
S9	Je suis prévenue quand quelque chose ne va pas	Haute	3	DEV RÉSEAU
S12	Mes clients n'oublient pas leurs rendez-vous (rappels 48 h et 24 h)	Haute	5	DEV RÉSEAU
S6	Mes clients signés réservent eux-mêmes leurs séances de suivi	Moyenne	3	DEV RÉSEAU
S10	Mes clients posent leurs questions et suivent les réponses (tickets)	Moyenne	3	DEV RÉSEAU
S13	Je garde le fil de chaque client (notes privées de la coach)	Moyenne	3	DEV RÉSEAU
S11	Mes visiteurs lisent le site sur téléphone, en anglais ou de nuit	Basse	2	DEV RÉSEAU

Sprint Backlog

47
tâches au Sprint Backlog

21
tâches Dev

16
tâches Réseau

10
tâches Mixte (Dev et Réseau ensemble)

Exemples de découpage d'une story en tâches des deux profils :

STORY	TÂCHES
S1 · adresse simple	RÉSEAU VPS durci (pare-feu, SSH par clé), nom de domaine, nginx + certificat Let's Encrypt · DEV build de production servi par nginx, en-têtes de sécurité
S7 · accès privé	RÉSEAU base, Adminer et supervision publiés sur l'interface locale seulement, tunnel SSH ou VPN · DEV rôle Coach vérifié côté API, rôle lu en base et jamais dans le jeton
S8 · récupération	RÉSEAU sauvegarde chiffrée nocturne · DEV suppression différée des documents (30 jours) · MIXTE test de restauration documenté
S10 · tickets	DEV espace de demandes côté client et back-office · RÉSEAU sauvegarde et surveillance incluent les tickets · MIXTE clarifier avec le client qui utilise les tickets et pour quoi

04

Déroulé du sprint

Ce journal est reconstitué à partir de l'historique du dépôt, des exécutions de la CI et des journaux du serveur. Les comptes-rendus de Daily détaillés sont sur Trello.

8	7	~2 min	0
passages de la CI sur main	verts (le premier, rouge, a révélé un oubli)	entre un push validé et la mise en ligne	mise en ligne sans sauvegarde préalable

> **MODÈLE DE COMPTE-RENDU DE DAILY (CARTE TRELLO)**
> Daily du [date] · présents · **Hier** · **Aujourd'hui** · **Obstacles** (carte créée ? qui la lève ?) · **Dev ↔ Réseau** : qui attend qui ?

Jour 1 · lundi 2 novembre : Planning et lancement

- Briefing client, auto-organisation, choix des rôles, création du tableau Trello et partage avec le client.
- Sprint Planning : Product Backlog initial, Sprint Goal, Definition of Done, Sprint Backlog (47 tâches).
- Choix techniques justifiés en langage simple : Linux (standard des serveurs web, léger, gratuit), C# .NET et React, Docker pour que « ce qui marche chez nous marche sur le serveur », Firebase pour la connexion (aucun mot de passe stocké chez nous), PostgreSQL pour les données.
- Création du dépôt et du squelette du projet (premiers commits à 15 h 46).

Jour 2 · mardi 3 novembre : Développement et changements

- Développement des stories prioritaires : site vitrine, réservation, connexion, espace client, back-office.
- Réunion client/PO : **plusieurs changements de besoin** (détaillés en partie 05) — notamment le retrait du VPN pour la coach, le travail 100 % à distance, les rappels par e-mail, les notes sur les clients.
- Pôle Réseau (Victor, Azzouz, Nathan) : VPS Linode préparé (pare-feu UFW, domaine `synego.duckdns.org`, certificat, supervision **Zabbix**, script de sauvegarde).
- Soirée : pipeline CI/CD complet et déploiement automatique ; premier passage de la CI **rouge** (des fichiers manquaient dans le dépôt), corrigé dans l'heure ; installation en production sur le VPS.

Jour 3 · mercredi 4 novembre : Adaptation et inspection

- Cohabitation du service avec l'infrastructure préparée par le pôle Réseau sur le même serveur (partie 06).
- **Urgence sécurité** : clé d'accès Google signalée publique par GitHub, avec des tentatives d'utilisation par des tiers. Restreinte, remplacée, l'ancienne supprimée (partie 06).
- Contenu demandé par le client : mentions légales, confidentialité et coordonnées **fictives** (projet pédagogique).
- Preuves produites sur le serveur réel : accès privé par tunnel, restauration testée, HTTPS valide.

- Découverte que le réseau de l'école **bloque** l'adresse du service (catégorie « Dynamic DNS ») : la démo se fera en 4G.

Jour 4 · jeudi 5 novembre : Finalisation et bilan

- Dernier Daily centré sur un incrément « Done » ; préparation des comptes de démo.
- Sprint Review : le PO raconte, l'équipe manipule (script en partie 12).
- Rétrospective interne (partie 11), compte-rendu posté sur Trello.

05

Changements demandés par le client

Le client a fait évoluer son besoin tout au long du sprint. Chaque demande a été reformulée par le PO, tracée dans Trello (étiquette CHANGEMENT), estimée, puis intégrée ou négociée.

ARBITRAGE : « JE NE VEUX PLUS PASSER PAR LE VPN »

Cette demande entrait en conflit avec le cadre imposé : *les données sensibles ne sont accessibles que par un tunnel SSH ou un VPN*. Plutôt que de dire non, le PO a proposé un compromis :

- **la coach** accède à son back-office depuis le site, comme ses clients, mais seulement après connexion et avec le rôle Coach, vérifié par le serveur dans la base (jamais par le navigateur) ;
- **les données brutes et les outils techniques** (base de données, Adminer, supervision, boîte d'e-mails de test, zone d'administration) restent invisibles depuis Internet et ne s'ouvrent qu'à travers un tunnel SSH ;
- une option (`ADMIN_VPN_ONLY=true`) remet le back-office derrière le VPN si le client change d'avis.

Dit au client : « Vous gérez vos rendez-vous et vos clients depuis votre téléphone, sans rien installer. Les coffres-forts, eux, restent fermés à clé : seule l'équipe technique peut les ouvrir. »

DEMANDE DU CLIENT	CE QUE NOUS AVONS FAIT	STATUT
Un site en anglais et un mode sombre	Traduction complète FR/EN vérifiée par TypeScript (aucune clé oubliée), thème sombre qui suit le téléphone ou le choix du visiteur.	FAIT
Utiliser Trello plutôt que Jira	Backlog versionné et import automatique dans Trello.	FAIT
Une interface pour la coach, qui relie son Calendly facilement	Back-office : la coach colle son jeton Calendly, choisit quel événement correspond à quel rendez-vous ; plus rien à configurer côté serveur.	FAIT
Un site 100 % utilisable sur téléphone	Passe responsive sur toutes les pages, menu mobile, vérification à 375-390 px.	FAIT
Une vitrine plus marquante, sereine, propre à la marque	Cadran-respiration animé, polices auto-hébergées, animations fluides et respect du réglage « réduire les animations ».	FAIT
Pas de locaux : tout se passe en visio	Textes revus, lien Google Meet récupéré depuis Calendly et envoyé dans le rappel.	FAIT
Rappels 48 h (avec annulation) et 24 h (lien Meet, plus d'annulation) ; ajout aux agendas	Service de rappels, e-mails aux couleurs de la marque en FR/EN, boutons Google, Apple, Samsung, Outlook et fichier .ics.	FAIT
Que la coach puisse prendre des notes sur ses clients	Notes privées épinglables dans la fiche client, jamais visibles du client, rappel « pas de données de santé ».	FAIT
Définir la coach principale, qui peut nommer d'autres coachs	Coach principale définie par configuration ; écran « Coachs » pour inviter ou retirer un coach.	FAIT
Gérer ses rendez-vous depuis l'espace client	Rendez-vous à venir et passés, déplacement et annulation jusqu'à 24 h avant, réservation sans quitter l'espace.	FAIT

DEMANDE DU CLIENT	CE QUE NOUS AVONS FAIT	STATUT
Retirer le VPN pour la coach	**Négocié** (encadré ci-dessus).	FAIT
Un pipeline complet et une mise en production automatique	GitHub Actions (5 contrôles) et déploiement automatique sur le VPS dès que la CI est verte.	FAIT
Mentions légales et contact avec des données fictives	Entreprise, personne et coordonnées fictives et clairement signalées comme telles ; hébergeur réel.	FAIT

06

Urgences et incidents

Pour chaque incident : comment il a été **repéré**, **tracé** et **réparti**, puis **traité** et **expliqué au client** sans jargon.

1. Une clé d'accès Google exposée publiquement URGENCE

Repéré	Alerte automatique de GitHub (« secret scanning », mention *Public leak*) sur la clé web Firebase écrite dans le code. En la restreignant, Google signalait en plus des appels à une API de géocodage que Synégo n'utilise pas : **quelqu'un testait la clé**.
Priorisé	En tête du Sprint Backlog : risque de facturation (envoi de SMS frauduleux) et d'abus.
Traité	1. Clé restreinte aux seules adresses du site (référents HTTP) : refusée partout ailleurs. 2. SMS de connexion limités à la France et aux pays francophones proches. 3. Nouvelle clé créée, restreinte aux sites *et* aux deux seules API de connexion. 4. Clé retirée du code : elle ne vit plus que dans le fichier `.env` du serveur et des postes. 5. Ancienne clé supprimée chez Google (vérifié : `API_KEY_INVALID`), alerte GitHub close comme « révoquée ».
Dit au client	*« Une des clés de votre site avait été rendue visible par erreur. Nous l'avons changée et l'ancienne ne fonctionne plus. Aucune donnée de vos clients n'a été touchée. »*

2. Le serveur était déjà occupé par le travail du pôle Réseau OBSTACLE

Repéré	À l'installation, le dossier du service existait déjà sur le VPS, avec une autre configuration : un squelette préparé par le pôle Réseau (nginx, certificat pour `synego.duckdns.org`, application de démonstration, base de test) et la supervision **Zabbix** servie par ce nginx sur le port 8443.
Cause	Le travail Dev et Réseau a avancé en parallèle sans inventaire partagé du serveur : exactement le piège « chaque profil dans son coin » décrit dans le sujet.
Traité	Rien n'a été supprimé : l'ancien dossier a été mis de côté, la configuration étrangère écartée. Le nginx du service reprend le rôle de l'ancien et continue de servir Zabbix sur 8443 ; le certificat couvre les deux adresses. Vérifié après coup : Zabbix répond toujours.
Reste à faire	Deux tâches planifiées du pôle Réseau (sauvegarde et renouvellement du certificat) visent encore l'ancien dossier : elles échouent sans dégât. À retirer par le pôle Réseau, le service ayant les siennes.
Dit au client	*« Les deux moitiés de l'équipe ont relié leur travail sur le même serveur : votre site et l'outil de surveillance tournent ensemble. »*

3. Le réseau de l'école bloque l'adresse du service RISQUE DÉMO

Repéré	Depuis le réseau de l'école, le pare-feu **Fortinet** affiche « Access Blocked » : les adresses `sslip.io` sont classées « Dynamic DNS ». Ce même équipement déchiffre et re-signe le HTTPS : le cadenas paraît invalide alors que le serveur présente bien un certificat Let's Encrypt valide (vérifié depuis le serveur et hors du réseau de l'école).

Traité	La démo se fera depuis un téléphone en **4G** (c'est d'ailleurs la preuve « accessible depuis l'extérieur »). Solution durable : un vrai nom de domaine (quelques euros par an).
Dit au client	*« Le réseau de l'école filtre ce type d'adresse. Vos visiteurs, eux, y accèdent normalement : regardez sur ce téléphone en 4G. »*

4. Incidents mineurs détectés par nos contrôles

- **Premier passage de la CI rouge** : une règle d'exclusion mal écrite, combinée à un Mac insensible à la casse, empêchait l'envoi de 6 tables et 8 migrations. La CI l'a vu avant la production ; corrigé et vérifié sur un clone neuf.
- **Une police bloquée par la politique de sécurité du site** : un petit fichier de police intégré au code était refusé par la CSP. Corrigé côté build, CSP gardée stricte.
- **Page Rendez-vous sans marges sur ordinateur**, repérée en préparant ce rapport : corrigée.

> **PROCÉDURES D'URGENCE PRÊTES**
>
> Le dépôt contient une fiche par urgence probable (`docs/scrum/urgences.md`) : site hors ligne, donnée effacée, compte compromis, attaque, certificat expiré, disque plein, panne d'un service partenaire. Chacune donne la commande à lancer et la phrase à dire au client.

07

Cadre technique imposé

BRIQUE	NOTRE SOLUTION	VALEUR POUR LE CLIENT	ÉTAT
1. Hébergement VPS	VPS Linode sous **Linux Ubuntu 26.10**, à jour à l'installation (« 0 updates »). Services en conteneurs Docker. Pare-feu UFW : seuls SSH, 80, 443, 8443 (Zabbix) et 51820/udp sont ouverts ; tout le reste écoute sur l'interface locale. *Pourquoi Linux* : standard des serveurs web, léger, gratuit, toutes nos briques y tournent nativement.	Le site est en ligne en permanence, chez un hébergeur reconnu.	FAIT
2. Accès sécurisé aux données	Base de données, Adminer, Uptime Kuma, Mailpit et zone d'administration publiés sur `127.0.0.1` uniquement : **refusés depuis Internet, accessibles par tunnel SSH** (preuve en partie 08). Scripts WireGuard prêts (`deploy/vps/02-wireguard.sh`) pour passer au VPN.	Même avec un mot de passe volé, personne n'atteint les données brutes depuis Internet.	FAIT
3. Base SQL	PostgreSQL 17, schéma `synego`. Comptes séparés : `synego_app` (l'API : lecture/écriture des lignes, aucun droit sur la structure), `synego_owner` (migrations), `synego_backup` et `synego_readonly` (lecture seule).	Chaque programme n'a que les droits dont il a besoin.	FAIT
4. Sauvegarde et restauration	Sauvegarde chiffrée (AES-256) chaque nuit à 2 h, gardée 14 jours, et **avant chaque mise en production**. Restauration testée sur une copie de la base (preuve en partie 08). Documents supprimés conservés 30 jours.	Une erreur ne fait rien perdre.	FAIT
5. Espace de tickets	Développé dans le service : demandes de devis et de contact depuis le site, demandes des clients depuis leur espace, fil de réponses, statuts Envoyée / En cours / Close dans le back-office. *Pourquoi développé* : les demandes sont liées au compte du client et à ses rendez-vous, sans outil de plus à apprendre.	Aucune demande perdue dans une boîte mail.	FAIT
Surveillance (DoD)	Point de santé `/api/health` (base + stockage), Uptime Kuma déployé (accès par tunnel), supervision Zabbix du pôle Réseau, CI qui bloque toute version cassée.	On est prévenu avant les clients.	PARTIEL

HONNÊTETÉ SUR L'ÉTAT

Le moniteur et la notification d'alerte d'Uptime Kuma (ou un déclencheur Zabbix sur `/api/health`) doivent encore être configurés et testés devant le PO avant la Sprint Review. Le VPN WireGuard est prêt mais non activé en production : l'accès privé passe aujourd'hui par tunnel SSH, ce que le cadre autorise.

08

Fiches de preuve

Pour chaque story : ce que veut le client, le test que le PO montrera, le résultat obtenu et les cases de la Definition of Done cochées. Les résultats ci-dessous sont les sorties réelles des tests, lancés sur le serveur de production le 4 novembre 2026.

S1 · « Mes visiteurs me trouvent à une adresse simple, avec le cadenas »

DÉMONTRÉ

Le test — Ouvrir l'adresse sur un téléphone en 4G ; vérifier le certificat et la redirection HTTP → HTTPS.

```
# depuis Internet
https://172-239-9-200.sslip.io/             200   certificat vérifié
https://172-239-9-200.sslip.io/api/health   200
{"status":"ok","database":true,"documents":true}
http://172-239-9-200.sslip.io/              301   → https://…
# certificat
émetteur : Let's Encrypt (YE2) · noms : 172-239-9-200.sslip.io, synego.duckdns.org · valide
jusqu'au 1er février 2027
```

DoD — ✓ accessible de l'extérieur · ✓ HTTPS valide · ✓ schéma à jour · ✓ FR/EN, clair/sombre, mobile · ◐ alerte à tester · ○ acceptation PO (jeudi)

S7 · « Mes informations sensibles ne sont accessibles que par un accès privé »

DÉMONTRÉ

Le test — Tenter d'ouvrir la base et les outils depuis Internet, puis à travers un tunnel SSH.

```
# sans tunnel, depuis Internet
port 8082 (Adminer, base)      refusé
port 3001 (Uptime Kuma)        refusé
port 8025 (Mailpit)            refusé
port 8444 (zone admin)         refusé
port 5432 (PostgreSQL)         refusé
# avec un tunnel SSH (clé de l'équipe)
Adminer (base)                 200
Uptime Kuma                    302  → tableau de bord
Zone admin (8444)              200
# API d'administration sans être connecté
https://…/api/admin/overview   401
```

DoD — ✓ données sensibles uniquement par tunnel · ✓ règles d'accès documentées (partie 09) · ✓ HTTPS valide · ○ acceptation PO (jeudi)

S8 · « Si une information est effacée par erreur, on la récupère »

DÉMONTRÉ

Le test — Restaurer la sauvegarde automatique dans une copie de la base, y effacer volontairement une information, restaurer à nouveau : l'information revient. La base réelle n'est jamais touchée.

```
1) Sauvegarde automatique la plus récente : synego_2026-11-04_090724.dump.enc (chiffrée AES-256)
2) Base réelle      : 1 compte(s), 0 ticket(s), 0 rendez-vous, 0 note(s)
3) Copie restaurée  : 1 compte(s), 0 ticket(s), 0 rendez-vous, 0 note(s)
4) Effacement volontaire, dans la copie, du compte 01a1a3be… (rôle Coach)
   Copie après effacement : 0 compte(s)
5) Nouvelle restauration : 1 compte(s)
   Compte effacé retrouvé : OUI
6) Copie temporaire supprimée. Base réelle inchangée : 1 compte(s)
```

DoD — ✓ sauvegarde existante · ✓ restauration testée · ✓ sauvegarde chiffrée · ○ acceptation PO (jeudi)

Pendant la démo : supprimer un document dans l'espace client, lancer `restore.sh`, le document réapparaît (le fichier est conservé 30 jours).

S10 · « Mes clients posent leurs questions et suivent les réponses »

À MONTRER EN DIRECT

Le test — Un visiteur envoie une demande de devis (référence n° affichée) → elle apparaît dans « Demandes à traiter » du back-office → la coach répond → le client voit la réponse dans son espace → la coach clôt la demande.

Résultat — Démonstration en direct jeudi (nécessite les comptes de démo). Tickets inclus dans la sauvegarde chiffrée.

DoD — ✓ accessible de l'extérieur · ✓ HTTPS · ✓ sauvegardé · ○ démontré et accepté

Mise en production fiable · « Une mise à jour ne casse rien »

DÉMONTRÉ

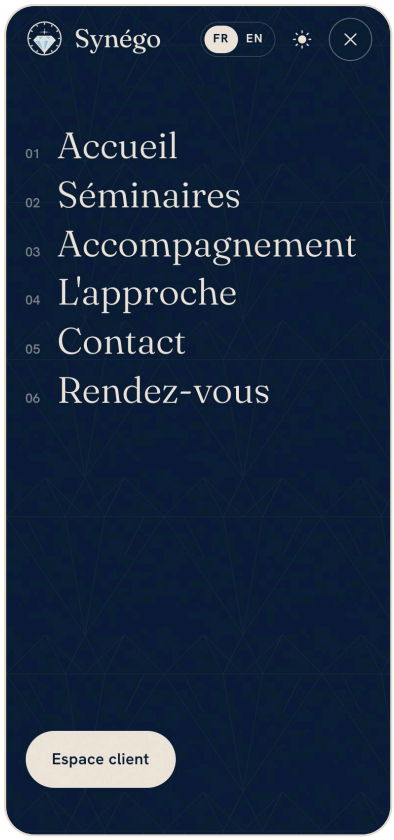
Le test — Pousser une correction : le serveur attend la CI, sauvegarde, déploie, vérifie la santé.

```
[synego-deploy] 09:18:26 CI en cours pour 26ed77d : on attend le feu vert.
[synego-deploy] 09:20:32 Déploiement 0728593 → 26ed77d : Contenu : mentions légales…
[backup]        09:20:32 OK : synego_2026-11-04_082032.dump.enc (24.0K)
[synego-deploy] 09:20:43 En ligne : 26ed77d.
```

S11 · « Mes visiteurs lisent le site sur téléphone, en anglais ou de nuit » DÉMONTRÉ



Téléphone, français, clair



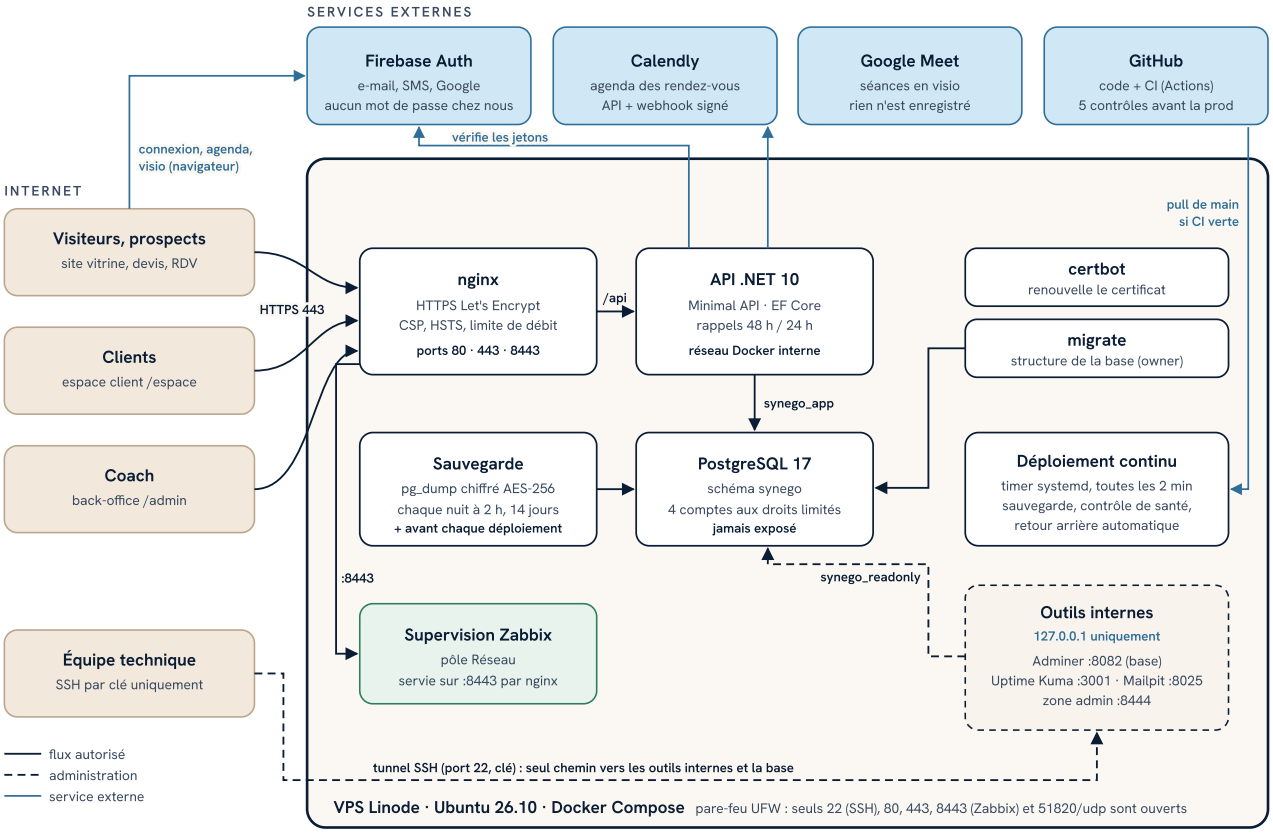
Menu mobile



Rendez-vous, thème sombre

09

Architecture et règles d'accès



Architecture en production au 4 novembre 2026 (schéma à jour).

Qui peut parler à quoi

DEPUIS	VERS	PORT	AUTORISÉ	POURQUOI
Internet	nginx	80, 443	OUI	Site et API publics (80 redirige vers 443)
Internet	Back-office `/admin`	443	OUI	Après connexion et rôle Coach vérifié en base
Internet	Zabbix (pôle Réseau)	8443	OUI	Interface de supervision, avec son propre compte
Internet	SSH	22	OUI	Administration par l'équipe (clé)
Internet	PostgreSQL, Adminer, Uptime Kuma, Mailpit, zone admin	5432, 8082, 3001, 8025, 8444	NON	Écoutent sur 127.0.0.1 : tunnel SSH obligatoire
nginx	API	8080 (Docker)	OUI	Seul point d'entrée de l'API
API	PostgreSQL	5432 (Docker)	OUI	Compte `synego_app`, sans droit sur la structure

DEPUIS	VERS	PORT	AUTORISÉ	POURQUOI
Sauvegarde	PostgreSQL	5432 (Docker)	OUI	Compte `synego_backup`, lecture seule
API	Firebase, Calendly, SMTP	443, 587	OUI	Vérification des jetons, rendez-vous, rappels
Serveur	GitHub	443	OUI	Récupère la branche main, lit l'état de la CI

PIÈGE ÉVITÉ : DOCKER CONTOURNE LE PARE-FEU

Un port publié par Docker passe outre UFW. C'est pourquoi seuls 80, 443 et 8443 sont publiés sur toutes les interfaces ; tous les autres sont liés explicitement à `127.0.0.1` (variable `ADMIN_BIND_IP`).

10

Definition of Done : état par story

✓ fait et prouvé · ◐ partiel · ○ à faire avant ou pendant la Sprint Review. Colonnes : Ext. = accessible de l'extérieur · HTTPS · Règles = règles d'accès documentées · Schéma · Surv. = surveillé avec alerte · Privé = données sensibles par tunnel · Sauv. = sauvegarde et restauration testées · Accept. = démontré au PO et accepté.

STORY	EXT.	HTTPS	RÈGLES	SCHÉMA	SURV.	PRIVÉ	SAUV.	ACCEPT.
S1 · adresse simple et sécurisée	✓	✓	✓	✓	◐	✓	✓	○
S2 · séminaires et devis	✓	✓	✓	✓	◐	✓	✓	○
S3 · réservation prospects	✓	✓	✓	✓	◐	✓	✓	○ *
S4 · connexion e-mail, SMS, Google	✓	✓	✓	✓	◐	✓	✓	○
S5 · documents confidentiels	✓	✓	✓	✓	◐	✓	✓	○
S6 · séances réservées aux clients signés	✓	✓	✓	✓	◐	✓	✓	○ *
S7 · accès privé aux données	✓	✓	✓	✓	◐	✓	✓	○
S8 · récupération après effacement	✓	✓	✓	✓	◐	✓	✓	○
S9 · être prévenue en cas de panne	✓	✓	✓	✓	○	✓	✓	○
S10 · tickets	✓	✓	✓	✓	◐	✓	✓	○
S11 · mobile, anglais, nuit	✓	✓	✓	✓	◐	✓	✓	○
S12 · rappels 48 h / 24 h	✓	✓	✓	✓	◐	✓	✓	○ **
S13 · notes de la coach	✓	✓	✓	✓	◐	✓	✓	○

* La coach doit relier son compte Calendly depuis le back-office (les liens de production sont encore ceux par défaut) et aligner les durées de ses événements Calendly sur les textes du site (45, 20 et 60 minutes).
** En production, aucun serveur d'e-mails réel n'est configuré : les rappels arrivent dans Mailpit (accessible par tunnel). Un compte SMTP (par exemple Brevo) suffit pour les envoyer réellement.

11

Rétrospective

Préparée à partir des faits du sprint, à valider en équipe jeudi puis postée sur Trello.

Start

- Un **inventaire partagé du serveur** (qui installe quoi, où, sur quel port) dès le jour 1.
- Une revue « aucun secret dans le code » avant chaque push.
- Tester la démo depuis le réseau où elle aura lieu, dès le jour 2.
- Configurer l'alerte de surveillance en même temps que le service qu'elle surveille.

Stop

- Avancer Dev et Réseau en parallèle sans point de jonction sur le serveur.
- Écrire des valeurs « par défaut » sensibles dans le code, même publiques.
- Laisser des tâches planifiées pointer vers un dossier qui peut bouger.

Continue

- La CI qui bloque toute version cassée : elle a arrêté le seul oubli grave avant la prod.
- La sauvegarde systématique avant chaque mise en production.
- Les preuves réelles, lancées sur le serveur, plutôt que des captures préparées.
- Le langage client : chaque urgence a sa phrase sans jargon.

Collaboration Dev ↔ Réseau

CE QUI A MARCHÉ	CE QUI A BLOQUÉ
• Une équipe équilibrée : 3 Dev, 3 Réseau ; le PO côté Dev, le Scrum Master côté Réseau. • Le serveur, le domaine, le certificat et la supervision Zabbix étaient prêts quand le service est arrivé. • La cohabitation a été réglée sans rien supprimer : Zabbix tourne derrière le nginx du service. • Le cadre imposé (accès privé) a servi d'argument commun face au client.	• Le déploiement a d'abord échoué faute de savoir ce qui existait déjà sur le serveur. • Deux tâches planifiées Réseau visent maintenant un dossier déplacé. • Le VPN WireGuard n'a pas été activé : l'accès privé repose sur le tunnel SSH.

Actions concrètes

ACTION	QUI	QUAND
Configurer et tester l'alerte sur `/api/health` (Kuma ou Zabbix), sur téléphone	Réseau + Dev	jeudi matin
Retirer les tâches planifiées obsolètes, inventaire du serveur dans le dépôt	Réseau	jeudi matin
Relier Calendly avec la coach, aligner les durées des événements	Luidgi (PO)	avant la démo
Passer SSH en clé uniquement, changer le mot de passe root	Réseau	sprint suivant
Sauvegardes hors du VPS, vrai nom de domaine, SMTP réel pour les rappels	Réseau, Dev, PO	sprint suivant

12

Bilan et préparation de la démo

13	5 / 5	3	1
stories livrées en production	briques du cadre technique en place	preuves lancées sur le serveur réel	urgence sécurité traitée de bout en bout

Script de la Sprint Review

Le PO raconte, un membre de l'équipe manipule. On montre, on ne raconte pas. **Tout se fait sur un téléphone en 4G**. Le détail des écrans et de l'exploitation figure dans la documentation utilisateur et la documentation technique.

#	CE QUE LE CLIENT VEUT	CE QU'ON MONTRE
1	« Mes visiteurs me trouvent à une adresse simple »	Ouvrir l'adresse en 4G : cadenas, FR puis EN, thème sombre
2	« Je mets en avant mes séminaires, sans prix »	Page Séminaires, « sur devis » ; envoyer une demande de devis
3	« Un prospect prend rendez-vous sans m'appeler »	Page Rendez-vous : réserver un audit dans Calendly, l'ajouter à son agenda
4	« Mes clients ont un espace privé »	Connexion Google puis par SMS ; documents, rendez-vous, demandes
5	« Les séances de suivi sont pour mes clients signés »	Compte non signé : séance verrouillée ; back-office : « Client signé » ; la séance s'ouvre
6	« Mes informations sensibles sont protégées »	Sans tunnel : Adminer ne répond pas ; avec le tunnel SSH : il s'ouvre, en lecture seule
7	« Une erreur ne fait rien perdre »	Supprimer un document, lancer la restauration, il réapparaît
8	« Mes clients posent leurs questions »	La demande de l'étape 2 : réponse depuis le back-office, visible côté client, clôture
9	« Je sais quand quelque chose ne va pas »	Arrêter l'API : l'alerte arrive sur le téléphone ; relancer

Avant la démo

- Partage de connexion 4G testé sur le téléphone et l'ordinateur de démo (le réseau de l'école bloque l'adresse).
- Un compte client de démo (non signé) et le compte coach ; Calendly relié depuis le back-office.
- Une sauvegarde récente : `docker compose exec backup backup.sh`.
- L'alerte testée une fois, le tunnel SSH ouvert dans un terminal prêt.